THREAT ADVISORY

Citrix NetScaler

28 Vulnerabilities Patched in ADC and Gateway

Citrix released updates on **12 November 2026** to fix **28 vulnerabilities** in NetScaler ADC and Gateway, including **9 critical flaws**. **CVE-2026-120868** affects default configurations; others depend on enabled features. The issues can cause unpredictable behaviour or denial of service. Administrators should patch affected appliances, prioritising internet-facing **Gateway and AAA deployments**.

Sources: **Citrix Security Bulletin CTX697305** · **CERT-EU Advisory 2026-020** · 12 November 2026

A patch across NetScaler services

Cloud Software Group released fixes on **12 November** for **28 vulnerabilities** in customer-managed NetScaler ADC and Gateway. The update fixes **9 critical**, **15 high** and **4 medium**-severity vulnerabilities.

NetScaler handles application delivery and remote access. Its exposure depends on the services each appliance processes, from load balancing to authentication and VPN traffic.

28
VULNERABILITIES

9
CRITICAL

9.5
HIGHEST CVSS v4.0

TWO EXPOSURE CONDITIONS

CVE-2026-120868 affects every deployment, including the default configuration. CVE-2026-107412 affects appliances operating as a Gateway or an AAA virtual server.

Citrix describes unpredictable behaviour and denial of service. High CVSS impact scores do not, by themselves, establish a working remote-code-execution exploit.

Several findings came from AI-assisted code analysis. Citrix also credits external researchers in the bulletin.

EXPOSURE AND PRECONDITIONS

Two reasons to prioritise patching

CVE-2026-120868 / PACKET PROCESSING / CVSS 9.3

A buffer-bounds failure in core packet processing affects ADC and Gateway **without requiring an additional feature**. The CVSS vector specifies network access, no privileges and no user interaction.

An appliance that does not use DNS load balancing, SMPP or a particular authentication method still meets this vulnerability's configuration condition.

CVE-2026-107412 / GATEWAY AND AAA / CVSS 9.5

This CVE groups **multiple memory overflows**. It applies to Gateway configurations using SSL VPN, ICA Proxy, clientless VPN or RDP Proxy, and to authentication, authorisation and accounting (AAA) virtual servers.

The vector specifies no authentication or user interaction, with an additional attack requirement (AT:P). The public advisory does not explain that requirement or provide a complete exploit mechanism.

> **PATCH PRIORITY**
>
> Prioritise **internet-facing Gateway and AAA appliances**. Other affected ADC deployments still require the update because the packet-processing flaw has no additional feature prerequisite.

OTHER CRITICAL VULNERABILITIES

Seven feature-specific critical flaws

Each entry below has a CVSS v4.0 base score of **9.3**. The configured feature determines which processing path is exposed.

CVE	SERVICE	CONFIGURATION CONDITION
CVE-2026-107407	SMPP	SMPP load-balancing or content-switching virtual server.
CVE-2026-107408	DNS / DoH	DNS load balancing and recursive DNS resolution.
CVE-2026-107409	DoH	DNS load balancing over HTTPS.
CVE-2026-107410	Push	Load-balancing virtual server of type PUSH.
CVE-2026-107415	Email OTP	Email Action configured.
CVE-2026-111334	EPA / EPAS	VPN or AAA virtual server with Endpoint Analysis.
CVE-2026-120864	ICA proxy	Gateway VPN, AAA or content-routing HDX virtual server.

These issues concern **memory overflow** or **corruption**. Citrix lists unpredictable behaviour or denial of service as the outcome.

Authentication and application processing

High and medium severity findings extend beyond the critical set. The entries below identify the affected function and CVSS v4.0 score.

CVE	CVSS	FUNCTION
CVE-2026-107413	8.7	SAML authentication
CVE-2026-107414	8.7	WebAuth authentication
CVE-2026-111340	8.7	Knowledge-based authentication
CVE-2026-111341	8.7	Client-certificate authentication
CVE-2026-111342	8.7	LDAP authentication
CVE-2026-111333	6.9	Authentication request handling
CVE-2026-111337	8.7	Base64 policy-expression decoding
CVE-2026-111338	6.9	Authentication material in logs
CVE-2026-111339	6.9	Application Firewall inspection

A DISTINCT DATA-EXPOSURE ISSUE

CVE-2026-111338 writes **sensitive authentication material** to /var/log/httperror.log. Exploitation requires **local read access** after a logout has occurred.

Traffic handling and management

These ten entries complete the 28-CVE inventory. Their reachability depends on the appliance configuration and the access conditions in the bulletin.

CVE	CVSS	FUNCTION / CONDITION
CVE-2026-107411	8.7	RTSP load balancing / ALG
CVE-2026-111335	6.9	Request handling; reboot-loop condition
CVE-2026-111336	8.3	HTTP/2-enabled HTTP profile
CVE-2026-120860	8.7	Diameter, SIP/TCP, MQTT, RADIUS
CVE-2026-120861	8.7	GSLB / geolocation functions
CVE-2026-120862	8.7	SIP ALG / DNS answer logging
CVE-2026-120863	8.7	Management plane: NSIP / NSIP6
CVE-2026-120865	8.7	HTTP/3 (QUIC) virtual servers
CVE-2026-120866	7.7	BGP neighbour without TCP-MD5
CVE-2026-120867	8.7	Specified TLS ECH / SafeNet HSM setups

Feature checks help establish individual exposure. Citrix still recommends upgrading when listed feature prerequisites appear absent, because the release includes additional security fixes.

AFFECTED VERSIONS AND FIXES

Which builds contain the fixes

For each supported branch below, builds earlier than the listed release are affected. Install that release or a later patched build in the same branch.

PRODUCT / BRANCH	FIXED FROM
ADC / Gateway 14.1	14.1-73.57
ADC / Gateway 13.1	13.1-64.39
ADC 14.1-FIPS	14.1-73.58 FIPS
ADC 13.1-FIPS / 13.1-NDcPP	13.1-37.293

CUSTOMER-MANAGED DEPLOYMENTS

The bulletin applies to appliances managed by customers. Secure Private Access Hybrid deployments using NetScaler instances must also update those instances.

CITRIX-MANAGED SERVICES

Citrix says the covered Secure Private Access, Gateway Service, Adaptive Auth and NetScaler Console Service environments have already received the security updates.

DEPLOYMENT AND EVIDENCE STATUS

Plan the upgrade and verify completion

ORDER AND SERVICE IMPACT

Citrix specifies upgrading **ADC/Gateway before NetScaler Console**. Existing **ICA sessions terminate during the upgrade** and must be started again afterwards.

For environments using pooled or flexed Console-based licensing, moving from a pre-14.1-51.x Console build may require a LAS exception or extension. Review the vendor's licensing sequence before scheduling the change.

CHECK THE UPGRADE RESULT

NetScaler Console can list affected instances in CVE Detection and initiate an upgrade workflow. Its assessment may take several hours to refresh; the documentation provides a Scan-Now option.

After the upgrade, confirm the intended build and check the application-delivery and remote-access functions used by the deployment.

EXPLOITATION STATUS AT DISCLOSURE

At publication, Citrix reported **no known unmitigated exploits** for the announced vulnerabilities. CERT-EU reported no confirmed public proof of concept. This describes the disclosure status on **12 November 2026**.